Pentest-Zwischenbericht

Karolinen-Gymnasium Rosenheim

Stand: 26. Oktober 2026 | Zwischenstand – keine vollständige Sicherheitsprüfung

Zweck
Dokumentation der bisher manuell beobachteten, überwiegend passiven Prüfungen an öffentlich erreichbaren Seiten. Dieser Bericht ist ein Zwischenstand und keine Bestätigung, dass das Gesamtsystem sicher oder unsicher ist.

Wichtige Scope-Grenze
Die Schulwebsite ist das Hauptziel. Schüler- und Elternportal liegen auf eigenen Domains und können extern betrieben werden. Bisherige Beobachtungen an diesen Portalen beschränken sich auf öffentlich sichtbare Inhalte und Browser-Entwicklertools. Keine Anmeldung, keine Umgehung von Zugriffskontrollen und keine aktiven Angriffe wurden dokumentiert.

Kurzüberblick

Bereich	Bisheriger Stand
Schulwebsite	HTTPS/HTTP-Weiterleitung beobachtet; nosniff vorhanden; mehrere weitere Header im untersuchten Response nicht sichtbar.
Schülerportal / PWA	HTTPS und HTTP-Weiterleitung beobachtet; Manifest mit 200 OK; Service Worker registriert; keine Fehlermeldung sichtbar.
Elternportal	Externe URL identifiziert; öffentliche Anmeldeseite vorhanden. Keine Tests im geschützten Bereich.
Bestätigte ausnutzbare Schwachstellen	Keine bisher bestätigt.

1. Umfang und Vorgehen

Die bisherigen Schritte erfolgten manuell mit dem Browser und Chrome DevTools. Es wurden öffentlich erreichbare Seiten, HTTP-Verhalten, sichtbare Response-Header, PWA-Manifest, Service-Worker-Status und Storage-Navigation betrachtet. Die Prüfung ist nicht vollständig und stellt keine umfassende Penetrationsprüfung dar.

Bekannte Domains

- Schulwebsite: https://www.karolinen-gymnasium-rosenheim.de/
- Schülerportal (PWA): https://schueler.schule-infoportal.de/login
- Elternportal: https://karogyro.eltern-portal.org/

Scope-Hinweis: Die Portale verwenden eigene Domains. Ob sie organisatorisch zum selben Betreiber gehören oder vollständig durch Dritte betrieben werden, ist anhand der bisherigen Beobachtungen nicht abschließend geklärt. Für weitere Tests an Portalen ist eine ausdrückliche Berechtigung für diese Systeme erforderlich.

2. Beobachtungen – Schulwebsite

Prüfpunkt	Beobachtung	Einordnung
HTTP → HTTPS	Weiterleitung auf HTTPS laut Nutzerbeobachtung.	Positiv; beobachtetes Verhalten.
X-Content-Type-Options	nosniff vorhanden.	Positiv; begrenzt auf den geprüften Response.
Strict-Transport-Security	Im untersuchten Response nicht gefunden.	Offen; noch kein bestätigter Befund.
Content-Security-Policy	Im untersuchten Response nicht gefunden.	Offen; noch kein bestätigter Befund.
X-Frame-Options	Im untersuchten Response nicht gefunden.	Nicht abschließend bewertet; CSP frame-ancestors nicht separat verifiziert.
Server / TYPO3-Header	Apache und X-TYPO3-* sichtbar.	Versions-/Technologiehinweise allein sind keine Schwachstelle.
Cache-Control	public und max-age=71979 im Screenshot beobachtet.	Nicht automatisch unsicher; kontextabhängig.
Cookie in Application	in2cookiemodal-selection; Secure/HttpOnly im letzten Screenshot leer, SameSite Strict; frühere Angabe zu Secure widersprüchlich.	Funktion und Sensitivität ungeklärt; niedrige Priorität, keine bestätigte Schwachstelle.

Hinweis zum Cookie: Es wurde kein Cookie-Wert dokumentiert oder übernommen. Der Name deutet möglicherweise auf eine Modal-/Consent-Auswahl hin, das ist aber nicht bestätigt. Ohne Prüfung der Funktion kann aus leeren Secure-/HttpOnly-Feldern keine belastbare Auswirkung abgeleitet werden.

3. Beobachtungen – Schülerportal (PWA)

Prüfpunkt	Beobachtung	Einordnung
HTTPS / HTTP	HTTPS aktiv; Aufruf über HTTP leitet auf HTTPS um.	Positiv; Transportverhalten beobachtet.
Login-Response	Network zeigt Status 304 Not Modified; im sichtbaren Response-Header-Block nur Date, Server: Apache, Connection, Keep-Alive, ETag.	304 ist normal. Fehlende Sicherheitsheader sind damit nicht abschließend bestätigt.
Sicherheitsheader	Strict-Transport-Security, Content-Security-Policy und X-Content-Type-Options wurden in der angezeigten 304-Antwort nicht gefunden.	Offen; 200-Response noch nicht zuverlässig geprüft.
PWA-Manifest	200 OK; JSON enthält name/short_name, theme_color, Icons, start_url='.', display='standalone', background_color und prefer_related_applications=false.	Plausible PWA-Konfiguration; keine klare Schwachstelle sichtbar.
Service Worker	service-worker.js registriert; Status '#70 activated and is stopped'; keine Fehlermeldung sichtbar.	Normaler möglicher Zustand; kein bestätigter Fehler.
Storage	Storage-Übersicht zeigt 8,2 kB bei Service workers. Local Storage wurde noch nicht geöffnet/ausgewertet.	Noch offen; keine Daten gelöscht oder verändert.

PWA-Dokumentation: Die bereitgestellte Installationsanleitung beschreibt das Schüler-Portal als Progressive Web App, die über den Browser installiert werden kann; Push-Benachrichtigungen benötigen Berechtigungen. Die Anleitung ist mit © art soft and more GmbH, 2023-08 gekennzeichnet.

4. Beobachtungen – Elternportal

Die URL https://karogyro.eltern-portal.org/ wurde vom Nutzer als externe Seite identifiziert. Es wurde nur die öffentliche Login-Seite betrachtet. Keine Anmeldung und keine Tests an geschützten Funktionen wurden durchgeführt. Der externe Betrieb bzw. die genaue Verantwortlichkeit ist aus den bisherigen Angaben nicht abschließend belegt.

5. Befunde und Priorisierung

ID	Beobachtung	Status
OBS-01	Schulwebsite: HSTS/CSP/X-Frame-Options im geprüften Response nicht gefunden.	Offene Beobachtung; keine bestätigte Schwachstelle.
OBS-02	Schulwebsite: Cookie-Attribute teilweise leer bzw. widersprüchlich beobachtet.	Funktion/Impact ungeklärt; niedrige Priorität.
OBS-03	Schülerportal: Sicherheitsheader nicht in der sichtbaren 304-Antwort aufgeführt.	Unbestätigt; vollständige 200-Antwort nötig.
OBS-04	PWA-Manifest und Service Worker funktionieren ohne sichtbare Fehlermeldung.	Informative Beobachtung, kein Befund.

Gesamtbewertung zum Zwischenstand: Es wurden bisher keine ausnutzbaren Schwachstellen bestätigt. Einige Header- und Cookie-Einstellungen sind noch offen und sollten nur innerhalb des autorisierten Scopes und anhand passender Antworten weiter verifiziert werden.

6. Nächste sinnvolle Schritte

- Schülerportal: Local Storage nur lesend prüfen; keine Schlüssel/Werte mit möglichen Tokens teilen.
- Schülerportal: Sicherheitsheader erst anhand einer vollständigen, passenden 200-Response bewerten.
- Schulwebsite: Header und Cookie-Attribute ggf. mit einem frischen, eindeutig identifizierten Response erneut dokumentieren.
- Vor aktiven Tests an Schüler-/Elternportal klären, ob diese externen Systeme ausdrücklich im schriftlich autorisierten Scope enthalten sind.
- Am Ende Ergebnisse, Zeitstempel und Belege konsolidieren; keine Zugangsdaten oder Session-Tokens in den Bericht aufnehmen.

Methodische Einschränkung: Dieser Bericht basiert auf manuellen Nutzerbeobachtungen und bereitgestellten Screenshots/Angaben. Header können je nach Antworttyp, Cache-Status, Pfad und CDN/Server-Konfiguration variieren. Die Angaben sind keine unabhängige Verifikation des Live-Systems.